CASE STUDY

The Binance Hot-Wallet Theft of October 2026: A Case Study

A TeamStarWolf case study. Published 12 November 2026; sources checked 11 November 2026, and the FBI alert opened 12 November 2026.

Executive summary

The people this touched first were three engineers. One downloaded a tampered installer in June, one sat through a fake job interview in September, and in October the attackers took over the computers of the first engineer and a third colleague [1] [2] (**Confirmed**, as Binance states). Behind them stood the exchange's customers, who found withdrawals suspended on 29 October after a loss of about $6.34 billion from Binance's hot wallets [1] [3] [15] (**Confirmed**; **Reported** for the suspension's timing). Binance says it bore the loss from its SAFU fund and treasury [3], and had replenished 98% of the affected token assets by 31 October [1] (**Confirmed**).

Most of the value left in minutes, though the theft window ran almost four hours. From about 20:05 UTC on 29 October, hot wallets on ten chains sent funds to attacker addresses, and most of the value had left within about 20 minutes [3] [9] (**Confirmed** for the start; **Reported** for the 20-minute figure). On Ethereum the attackers used signed EIP-7702 authorizations that acted outside the withdrawal system and kept working after Binance paused withdrawals, because the MPC hot wallet had no single key that could revoke them; Binance cleared the delegation at 00:10 UTC on 30 October [1] [2] (**Confirmed**). Stablecoin issuers and others froze about $2.85 billion [1] (**Confirmed**). About $2.4 billion in ETH and BTC stayed with the attacker [10] (**Reported**).

On 31 October the FBI stated that North Korea was responsible and called the activity TraderTraitor, naming the US Secret Service and IRS-CI as its partners [28] (**Confirmed**). Binance cites the FBI's finding rather than making its own [2] (**Confirmed**). No CVE applies: this was an intrusion into Binance's own people and systems, not a flaw in a vendor product [1] [23] (**Inferred** from the record; the empty CVE field is **Demonstrated**).

Key facts at a glance

Field	Value
Victim	Binance, a centralized cryptocurrency exchange; hot wallets on ten chains (TRM) or 11 (Elliptic) [9] [14]
Theft window	From about 20:05 UTC on 29 Oct 2026 to the final transfer at 23:56 UTC [1] [3]
Loss	About $6.34 billion (Binance post-mortem); estimates range from $5.8 billion to $6.43 billion [1] [16] [19]
Frozen or intercepted	About $2.85 billion (Binance, 3 Nov) [1]
Entry	A tampered Homebrew installer (June 2026) and a fake job process with a malicious coding assignment (September 2026) [1] [2]
Path to the wallets	An internal AI tool, a stolen container deployment token and the hot wallet signing service [2]
Attribution	FBI with USSS and IRS-CI: North Korea, "TraderTraitor" (31 Oct 2026) [28]; Binance cites the FBI [2]
CVE and KEV	None applies [1] [23]
Customer impact	Withdrawals suspended 29 Oct; phase-one withdrawals resumed 1 Nov on 15 networks [3] [4]

Key findings

- **Most of the money moved in about 20 minutes, but the intrusion took five months.** Binance traces the chain from a June installer download through a September fake interview to the 29 October container deployment [1] [2] (**Confirmed**). Co-CEO Richard Teng called it a "months-long campaign" [21] (**Reported**).
- **The endpoint tools missed the second foothold.** The September assignment swapped a legitimate pyenv component for a malicious one, and Binance says its endpoint tools did not detect it [1] (**Confirmed**).
- **An internal AI tool became the lateral path.** On 20 October the attackers used it from one engineer's machine to take control of two others [1] (**Confirmed**).
- **Freezes held 44% of the theft.** Elliptic verified $2.85 billion frozen or seized, 44% of the theft and 94% of it stablecoins, while about $786 million in stablecoins was converted before freezes landed [14] (**Confirmed** as Elliptic's figures).
- **The attribution chain runs through analytics firms first.** Chainalysis named TraderTraitor about eight hours after the theft began, on the strength of commingling with Bitget theft proceeds [12] (**Reported** as an attribution); the FBI followed on 31 October [28] (**Confirmed**).

Top recommendations

1. Treat staff with access to wallet, deployment or signing systems as high-value targets. Route unsolicited recruiting approaches and take-home assignments to isolated, disposable machines [13] [1] (**Inferred**).
2. Keep no reusable deployment tokens on workstations. Issue short-lived, scoped tokens and revoke them on any device change [1] [2] (**Inferred**).

3. Put internal AI and automation tools that can act on other endpoints under the same access control and logging as administrative tools [2] (**Inferred**).
4. Let the signing service sign only what the withdrawal flow has approved, and monitor on-chain delegations independently of the withdrawal switch [2] (**Inferred**).
5. Arrange freeze channels with issuers in advance, and screen downstream exposure to the 628 addresses the FBI published [28] [10] (**Inferred**).

Scope and method

This brief covers the October 2026 theft from Binance, the intrusion that led to it, the attribution and the response through 11 November 2026. It does not repeat the October 2026 roundup in PHP2Shell and October 2026 [26], or the longer North Korean record in North Korea-Attributed Threat Actors [24]. The 2026 chronicle [29] summarizes this theft in one paragraph and links here as the home study. Tradecraft is described at advisory level; no addresses, contract details or code appear here. Binance gives its own times in UTC+8 and US sources use Eastern time; this brief converts both to UTC and keeps the original where it matters.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the victim's own statements, a government advisory, the MITRE page or data, or an analytics firm's own published figure, as that firm's figure
Reported	Known through journalism, through a secondary account of a primary that could not be opened, or as a researcher's attribution or judgement that this study cannot check against primary evidence
Demonstrated	Shown by this study's own check of data (the Hub feed, the IC3 index, the library's ATT&CK files)
Inferred	This study's own reasoning from cited facts, labelled where it appears

The FBI alert returned HTTP 403 when this brief was researched on 11 November and opened on 12 November 2026; what it states is **Confirmed** from the alert itself [28], and press accounts of it [18] [19] [20] are kept only for what the alert does not say.

Part 1: what happened

Date and time (UTC)	Event	Sources	Grade
18 Apr 2022	CISA, the FBI and Treasury describe TraderTraitor in AA22-108A: recruitment-themed spearphishing of DevOps and system administrator staff, delivering trojanized cryptocurrency applications	[5]	Confirmed
26 Feb 2025	IC3 I-022625-PSA attributes the theft of about $1.5 billion from Bybit, on or about 21 Feb 2025, to North Korea and names the activity TraderTraitor	[6]	Confirmed
June 2026	Engineer A, a wallet developer, downloads a tampered Homebrew installer. It is detected, the device replaced and credentials rotated, but the engineer's role and colleague information are already exposed	[1] [2]	Confirmed (as Binance states)
September 2026	Bitget theft, whose proceeds later commingle with Binance's	[12]	Reported
September 2026	Engineer B, a software engineer, goes through a fake job process: two interview rounds with a fictitious company, then an "assignment" repository whose install script replaces a pyenv component. Endpoint tools do not detect it	[1] [13]	Confirmed; Reported for the job-platform detail
13 Oct 2026	IC3 I-101326-PSA warns that North Korean remote IT workers increasingly use facilitators and fraudulent hiring tradecraft (context, not about Binance)	[8]	Confirmed
20 Oct 2026	From Engineer B's machine, the attackers use an internal AI tool to take control of the devices of Engineers A and C. Engineer A's computer holds a token with container deployment permissions	[1] [2]	Confirmed
At least 36 hours before the theft (by about 08:05 on 28 Oct)	Preparation under way, per TRM	[9]	Reported; Inferred for the converted time
29 Oct, 17:15 to 19:56 as Binance gives it (time zone not checked; see Discrepancies)	The attackers deploy a container with the stolen deployment token and abuse the hot wallet signing service	[2]	Confirmed; time zone not checked
29 Oct, 20:05	Hot wallets compromised	[3]	Confirmed
29 Oct, 20:05 to 20:09	Five hot wallets send 233.46 million XRP; Solana and Optimism hot wallets send about 970,500 SOL and 44.2 million OP; 18,270 BTC follows	[1]	Confirmed
29 Oct, 20:20 (16:20 ET)	Ethereum sweeper authorizations submitted (TRM); 50 signed EIP-7702 transactions delegate partial execution rights over affected wallets to an attacker contract (Binance). Chainalysis dates the first outflows to about this time	[1] [9] [12]	Confirmed; Reported for TRM's time

Date and time (UTC)	Event	Sources	Grade
29 Oct, 21:14 (17:14 ET)	Freezes begin, per Chainalysis	[12]	Reported
29 Oct, 22:27 (15:27 PDT)	TechCrunch reports withdrawals halted on multiple networks; founder Changpeng Zhao says on X the exchange was likely hacked	[15]	Reported
29 Oct, 6:45 p.m. ET as published	BleepingComputer reports a potential breach of up to $5.8 billion from Arkham-tracked wallets and a spokesperson saying user funds are safe	[16]	Reported
29 Oct, about 23:05	Second wave from Avalanche and Polygon hot wallets	[9]	Reported
29 Oct, 23:56	Final unauthorized transfer, 2,961.9 ETH	[1] [2]	Confirmed
30 Oct, 00:10	Binance clears the EIP-7702 delegation on its Binance14 hot wallet by authorizing a null address; no further unauthorized transfers	[1] [2]	Confirmed
30 Oct, 00:30	About $2.7 billion frozen, per TRM	[9]	Reported
30 Oct, 04:30 (00:30 ET)	Chainalysis announces its TraderTraitor assessment	[12]	Confirmed (as Chainalysis's assessment)
30 Oct	Binance Security Incident Update #2: about $6.3 billion, withdrawals suspended, deposits open, about $3 billion frozen, over $6.34 billion set aside, no evidence of private-key leakage; Teng tells BleepingComputer it was not a single one-click action; Elliptic assesses North Korea as likely (before the FBI alert); ZachXBT reports commingling with Bitget proceeds	[3] [14] [17] [22]	Confirmed; Reported for Teng and ZachXBT
31 Oct	FBI cyber alert, with USSS and IRS-CI: North Korea responsible for more than $6 billion, "TraderTraitor"; 628 laundering addresses for VASPs to block. Elliptic logs it at 23:55. Binance reports 98% of assets replenished (UTC+8)	[1] [14] [28]	Confirmed for the FBI alert and Binance; Reported for Elliptic's time
31 Oct to 2 Nov	Laundering through a self-minted TRON token and liquidity pool, lending receipt tokens and chained cross-chain swaps	[10]	Reported
1 Nov, 06:00 to 09:00	Phase-one withdrawals resume on 15 networks; about 95% of the impacted amount covered	[4]	Confirmed
1 Nov, 06:00 to 15:30	$4.649 billion withdrawn and $1.01 billion deposited, a net outflow of about $3.64 billion	[19]	Reported
2 Nov	Kim Yo Jong denies North Korea's role, calling the accusation absurd (the KCNA source was not opened)	[21]	Reported
3 Nov	Binance publishes its preliminary post-mortem; Chainalysis and TRM publish follow-ups; Chainalysis puts the frozen total at about $2.8 billion at 16:30 (11:30 ET)	[1] [2] [10] [12] [13] [21]	Confirmed for Binance; Reported for Chainalysis, TRM and The Record

Date and time (UTC)	Event	Sources	Grade
11 Nov	IC3's PSA index lists no Binance PSA; the Hub feed's Binance rows carry no CVE	[7] [23]	Demonstrated

Discrepancies in the record

- **Loss.** $5.8 billion (early wallet tracking) [16], $6.3 billion (Update #2) [3], $6.34 billion (post-mortem) [1], $6.36 billion at time-of-theft prices and $6.23 billion at later prices (TRM) [9], $6.4 billion (Chainalysis) [12] and $6.43 billion (Elliptic and The Hacker News) [14] [19]. This brief leads with Binance's $6.34 billion (**Inferred** choice).
- **Frozen.** About $2.7 billion (TRM) [9], about $3 billion (Update #2) [3], $2.8 billion (Chainalysis) [12] and $2.85 billion (Binance post-mortem and Elliptic) [1] [14]. Binance's later figure is lower than its earlier one. Tether's freeze is "more than $1.567 billion" in the CEO post BleepingComputer relays [16] and about 1.77 billion USDT in TRM's count [9].
- **Chain count.** Ten (TRM) [9] against 11 (Elliptic and The Hacker News) [14] [19].
- **Stale text.** TRM's 3 November update still says no government has attributed the theft, after the FBI alert [10].
- **Replenishment.** Binance gives 98% of affected token assets replenished by 31 October [1] and about 95% of the impacted amount covered on 1 November [4]; the two figures measure different things and are not a decline.
- **Start time.** 20:05 UTC (Binance, TRM, Elliptic) against about 20:20 UTC (Chainalysis, which may be dating the Ethereum sweep) [1] [3] [9] [12] [14].
- **Container window.** Binance gives 17:15 to 19:56 for the container deployment [2]. Binance states other times in UTC+8, and [2] could not be reopened for this brief, so whether that window is UTC or UTC+8 (09:15 to 11:56 UTC) is not checked.

Part 2: the intrusion record

First foothold, June 2026. The Part 1 row holds Binance's account: the installer was caught, but the engineer's role and colleague information was already exposed [1] (**Confirmed**). Binance does not say how that information was used; that a colleague was the next target fits reconnaissance of roles (**Inferred**).

Second foothold, September 2026. Binance describes a video interview and an "assignment" repository whose install script swapped a pyenv component undetected [1] (**Confirmed**); the job-platform detail is Chainalysis's [13] (**Reported**). Chainalysis ties this to a North Korean fake-interview playbook refined over dozens of smaller attacks, with more than $14.3 million in such losses over 18 months [13] (**Reported**).

Lateral movement, 20 October. The Part 1 row holds Binance's account of the AI tool and the deployment token [1] (**Confirmed**). Teng later said the attacker did not simply use one engineer's permissions [17] (**Reported**).

The theft path, 29 October. Between 17:15 and 19:56 as Binance gives it (time zone not checked; see Discrepancies) the attackers deployed a container with the stolen deployment token and abused the hot wallet signing service [2] (**Confirmed**). Binance says the attackers used the internal wallet signing service to initiate

the first transactions [2] [21] (**Confirmed** as Binance states), which implies the service could start transactions outside the withdrawal flow (**Inferred**). Binance found no evidence that wallet private keys leaked [3] (**Confirmed**). Chainalysis and Elliptic report that on the other chains funds left in ordinary signed transactions [12] [14] (**Reported**). On Ethereum, 50 signed EIP-7702 transactions delegated partial execution rights over affected hot wallets to an attacker-controlled contract [1] (**Confirmed**). Teng said on 31 October that a self-destruct mechanism destroyed the attacker's tooling and traces [20] (**Reported**), and Binance's post-mortem, as The Record relays it, says the attacker removed traces of the initial compromise [21] (**Reported**).

Why the pause did not stop it. The on-chain delegations sat outside the withdrawal system, so they outlived the pause until the special revocation in the Part 1 rows for 23:56 and 00:10 UTC [1] [2] (**Confirmed**).

Laundering. The Part 1 row for 31 October to 2 November holds TRM's trace [10], and Elliptic counted about 12,000 wallets and about 40,000 laundering transactions [20] (**Reported**). The FBI and its partners observed conversion primarily into ETH and expected further laundering through DeFi and instant swap services [28] (**Confirmed**).

Part 3: who and why

The government record. The FBI alert in the Part 1 row for 31 October names North Korea and the activity TraderTraitor [28] (**Confirmed**). The library's North Korea study records press reports of public doubt about the attribution, including from the US President [24] (**Reported**). The Secret Service said it worked with industry and the Justice Department to freeze a significant share within minutes [20] (**Reported**). As of 11 November IC3's PSA index lists no Binance PSA; the newest entries are PSA261023 and PSA261023-2 [7] (**Demonstrated**).

The victim's position. Binance's post-mortem does not name an actor on its own authority. It cites the FBI's latest information that North Korea is responsible, and does not use the name TraderTraitor [2] (**Confirmed**). It also says Binance detected and blocked 57 suspected North Korea-linked incidents during 2026 [1] [2] (**Confirmed**).

The analytics firms. TRM attributes the theft to TraderTraitor with high confidence [9]. Chainalysis cites as its strongest evidence the real-time commingling of Binance proceeds with funds from the September Bitget theft [12]. Elliptic assessed North Korea as likely before the FBI notice, citing Bitget links, overlap with earlier TraderTraitor thefts and a method similar to Bybit's [14]. ZachXBT said the Binance and Bitget proceeds met at the same address after passing through THORChain [22]. All of these are **Reported** as attributions.

What TraderTraitor is. AA22-108A calls TraderTraitor a North Korean state-sponsored APT, active since at least 2020, that industry tracks as Lazarus Group, APT38, BlueNoroff and Stardust Chollima. It targets exchanges, DeFi protocols and trading firms with trojanized cryptocurrency applications [5] (**Confirmed**). The Hacker News lists the aliases Jade Sleet, Pressure Chollima, PUKCHONG, Slow Pisces and UNC4899 [19] (**Reported**). GitHub's 2023 attribution of a malicious-npm social-engineering campaign to Jade Sleet/TraderTraitor is recorded in npm Supply Chain Attacks [25] (**Confirmed** as the library records it).

The denial. The Record reports that Kim Yo Jong denied North Korea's role on 2 November, calling the accusation absurd [21] (**Reported**).

Why. TRM estimates North Korea has stolen about $12.8 billion in cryptocurrency since 2017 across about 100 incidents, $7.4 billion of it in 2026: 85% of the year's $8.7 billion in crypto hack value [11] (**Confirmed** as TRM's figures). Binance alone is most of that 2026 total (**Inferred**).

Part 4: impact and response

Victim and sector. One centralized exchange was the victim; Binance says it bears the loss through SAFU and its treasury [3] (**Confirmed**), and a spokesperson said user funds were safe [16] (**Reported**). The sector cost is wider: about $2.4 billion stayed in attacker hands [10] (**Reported**), and the FBI asked THORNode and RPC node operators, instant exchanges, DeFi services, analytics firms and other VASPs to block transactions tied to 628 laundering addresses [28] (**Confirmed**).

The freeze response. Stablecoin issuers and others froze funds within hours; the competing totals sit in Discrepancies [9] (**Reported**), and Elliptic verified $2.85 billion, 94% of it stablecoins [14] (**Confirmed** as Elliptic's figure). Founder Changpeng Zhao credited US law enforcement with helping track and freeze funds [20] (**Reported**).

Binance's containment and recovery. Deposits stayed open, more than $6.34 billion was set aside and about 80% replenished by 30 October [3], before the 31 October and 1 November figures in Part 1 [1] [4] (**Confirmed**). Ten major assets were fully backed on 1 November [4] (**Confirmed**). Between 06:00 and 15:30 UTC on 1 November, $4.649 billion left and $1.01 billion arrived [19] (**Reported**).

Remediation. As of 3 November Binance had rebuilt the wallet system and the internal AI tool with new access controls, replaced devices, retired credentials and tokens, scanned all employee devices, expanded behavioral anomaly detection and tightened device controls. It plans an independent third-party review [2] (**Confirmed**).

Government and regulator record. The 628 addresses are 608 Ethereum, 19 Bitcoin and one Solana [28] (**Confirmed**; counted on the alert page for this brief). No regulator filing was opened for this brief.

KEV. No CVE is tied to the theft, so no KEV date applies [1] [23] (**Inferred**; the KEV catalog itself was not checked for this brief).

Part 5: the defender and vulnerability-management view

What mattered. Fast issuer freezes and Binance's internal large-transfer alert limited the loss; the gaps in the table below enabled it [2] [14] (**Inferred** from the record).

Control	Where it meets the record
Disposable, isolated machines for interview assignments and unsolicited code	Engineer B's assignment repository [1] [13]
Verify developer-tool installers and watch for changes to toolchain components such as pyenv	The tampered Homebrew installer and the swapped pyenv component [1]
Short-lived, scoped, device-bound deployment tokens	The token on Engineer A's computer [1] (**Inferred**)
Access control and logging on internal AI tools that act on endpoints	The 20 October lateral movement [1] [2]

Control	Where it meets the record
A signing service that signs only what the withdrawal flow approved	The 29 October signing abuse [2]
On-chain delegation monitoring and a rehearsed MPC revocation procedure	The EIP-7702 delegations that outlived the pause [2]
Downstream multi-hop screening and real-time alert sharing among VASPs	TRM's recommendations [10]

The vulnerability-management lens. Several points follow (**Inferred** throughout):

- A program that ranks work by CVE or KEV would have seen nothing here. The exposure was people, tokens and internal tools.
- Developer workstations that hold deployment rights, and internal AI tools with endpoint reach, belong in the inventory as privileged systems.
- Treat recruiting contact with wallet and DevOps staff as a threat indicator. AA22-108A warned of exactly this audience in 2022 [5], and the IC3's October 2026 alert shows the hiring channel still in use [8].

What is overstated and what is understated

- *Overstated:* coverage that has Binance blaming TraderTraitor; Binance names neither North Korea on its own authority nor TraderTraitor, and cites the FBI [2] (**Confirmed**). The "compromised DevOps laptop" framing of the first days [17] understates a campaign that ran from June to October across three engineers [1] (**Confirmed**). "$6.3 billion lost" overstates the final loss once about $2.85 billion was frozen [1] (**Inferred**).
- *Understated:* about $2.4 billion stayed with the attacker [10], and Binance's replenishment hides that sector-wide cost (**Inferred**). Pausing withdrawals did not stop the theft, a point that applies to any exchange using delegated on-chain authorizations [2] (**Confirmed** for Binance; **Inferred** beyond it). The 57 suspected North Korea-linked incidents Binance says it blocked in 2026 [1] [2] (**Confirmed** as Binance states) show the volume this one success came out of (**Inferred**).

Part 6: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CAPEC and D3FEND. Names and tactics come from `data/attack/technique_profiles.jsonl`, `data/attack/groups.jsonl` and `data/attack/campaigns.jsonl` [27]. No source names ATT&CK ids; each mapping is this study's reading of a behavior a cited source describes. The incident touches no industrial system, so no ATT&CK for ICS techniques apply.

6.1 Groups, software and campaigns

ATT&CK has no TraderTraitor, Jade Sleet or UNC4899 object in the library's data [27] (**Demonstrated**). Binding TraderTraitor to any one ATT&CK group would be inference only, so this study binds none. The objects below are related, not bound.

Object	ATT&CK id	Relationship to this record
APT38	G0082	Its ATT&CK aliases include Bluenoroff and Stardust Chollima, two of the industry names AA22-108A gives for TraderTraitor [5] [27]; ATT&CK describes it as targeting cryptocurrency exchanges. Overlap only (**Inferred**)
Lazarus Group	G0032	An industry name AA22-108A gives for TraderTraitor [5]. Overlap only (**Inferred**)
Contagious Interview	G1052	A separate North Korea-aligned group ATT&CK records as targeting software developers and cryptocurrency work [27]. Comparison only; no source links it to Binance
Operation Dream Job	C0022	An ATT&CK campaign whose tradecraft includes fake job lures [27]. Comparison only; no source links it to Binance
AppleJeus	S0584	Malware AA22-108A ties to TraderTraitor [5]. Comparison only; no source names it in the Binance record

No software object is bound: the record names neither the tampered installer's payload nor the malicious pyenv component [1].

6.2 ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1591.004	Identify Roles	Reconnaissance	Engineer A's role and colleague information exposed (June 2026); its use to pick the September target is this study's inference (**Inferred**)	[1]
T1608.001	Upload Malware	Resource Development	The "assignment" code repository carrying the malicious install script (September 2026); reading it as staged malware is this study's inference (**Inferred**)	[1]
T1566.003	Spearphishing via Service	Initial Access	Approach through a legitimate job platform and two interview rounds (September 2026; Chainalysis, 3 Nov 2026)	[13] [1]
T1204.002	Malicious File	Execution	Tampered Homebrew installer run (June 2026); assignment install script run (September 2026)	[1] [2]
T1036.005	Match Legitimate Resource Name or Location	Stealth	A legitimate pyenv component replaced with a malicious one, undetected (September 2026)	[1]
T1072	Software Deployment Tools	Execution, Lateral Movement	An internal AI tool used to take control of Engineers A and C's devices (20 Oct 2026)	[1] [2]
T1552	Unsecured Credentials	Credential Access	A token with container deployment permissions held on Engineer A's computer (20 Oct 2026)	[1]
T1550.001	Application Access Token	Lateral Movement	The stolen deployment token used to deploy a container (29 Oct 2026, 17:15 to 19:56 as Binance gives it; time zone not checked)	[2]
T1610	Deploy Container	Execution	A container deployed with the stolen token, after which the signing service was abused (29 Oct 2026)	[2]
T1070	Indicator Removal	Stealth	A self-destruct mechanism destroyed tooling and traces (Teng, 31 Oct 2026, via The Record); traces of the September compromise removed (Binance post-mortem, via The Record, 3 Nov 2026)	[20] [21]
T1657	Financial Theft	Impact	About $6.34 billion moved from hot wallets from 20:05 UTC on 29 Oct 2026	[1] [3] [9]

Fit notes (**Inferred**): T1072 fits by function, because the record describes an internal tool used to control other endpoints, not a named deployment suite. T1552 is left at the parent because the record does not say where on the computer the token sat. Valid Accounts is not bound, because the record names a token rather than an account login and Teng said the attacker did not simply use one engineer's permissions [17]. The signing-service abuse, the EIP-7702 delegations and the laundering have no ATT&CK technique and are left unmapped.

6.3 CWE and CAPEC

No CVE applies, so no CNA has assigned a CWE, and this study binds none. The closest weakness class for a reusable deployment token left on a workstation would be CWE-522, Insufficiently Protected Credentials (**Inferred**, not bound) [27].

CAPEC entries the library relates to this study's techniques that meet the record [27]:

CAPEC	Name	Via	Where it meets the record
CAPEC-163	Spear Phishing	T1566.003	The fake job approach [13]
CAPEC-616	Establish Rogue Location	T1036.005	The tampered installer and the swapped toolchain component stand in for legitimate ones [1] (**Inferred**)
CAPEC-593	Session Hijacking	T1550.001	Reuse of the stolen deployment token [2] (**Inferred**, partial fit)

CAPEC-543, CAPEC-187, CAPEC-657 and CAPEC-268, which the library also relates to these techniques, are left out because nothing in the record matches them.

6.4 D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Executable Allowlisting (D3-EAL)	T1204.002	The tampered installer and the assignment script [1]
Dynamic Analysis (D3-DA)	T1204.002	Detonating take-home assignments before anyone runs them (**Inferred**)
File Integrity Monitoring (D3-FIM)	T1204.002, T1036.005, T1072, T1566.003	The swapped pyenv component the endpoint tools missed [1]
URL Reputation Analysis (D3-URA)	T1566.003	Links in recruiting approaches (**Inferred**)
Credential Rotation (D3-CRO)	T1550.001, T1552	The June credential rotation [1]
Credential Revocation (D3-CR)	T1550.001, T1552	Credentials and tokens retired after the theft [2]
Credential Compromise Scope Analysis (D3-CCSA)	T1550.001, T1552	Working out what the June exposure reached, which the record shows was underestimated [1] (**Inferred**)
Token Binding (D3-TB)	T1550.001	Binding deployment tokens to a device would have blocked reuse from another machine (**Inferred**)

See the D3FEND Reference.

6.5 Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/binance-heist-2026.json` (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20, domain `enterprise-attack`, with the techniques of 6.2. A score of 100 means Binance's own record states the behavior and the technique fits directly; 60 means Binance's record states the behavior and the fit is this study's inference; 40 means the behavior is known only from Reported sources. Scores measure the strength of the tie to this record, not severity. T1591.004, T1608.001 and T1072 are inferred readings and score 60; T1566.003 scores 40 because the job-platform detail it turns on is Chainalysis's [13], and T1070 scores 40 because it is known only through The Record [20] [21]. Each comment names the event and the source numbers.

Cross-cutting themes

- **The hiring channel is an access channel.** AA22-108A warned in 2022 that TraderTraitor courts DevOps and system administrator staff with recruitment lures [5]; in 2026 a fake interview opened the door to a $6 billion theft [1] [13] (**Confirmed**; **Reported** for the job-platform detail).
- **Developer tooling is supply chain.** A tampered package-manager installer and a swapped toolchain component did the work a vendor CVE does elsewhere [1]. The pattern echoes the malicious-npm campaign in npm Supply Chain Attacks [25] (**Inferred**).
- **Internal AI tools are privileged systems.** One moved the attackers between engineers' machines [1] (**Confirmed**); see AI Threats in the Cybersecurity Industry.
- **Freezes are a control, but only for some assets.** Stablecoins were 94% of what was frozen [14] (**Confirmed** as Elliptic's figure); ETH and BTC largely were not [10] (**Reported**).
- **Attribution now runs at blockchain speed.** Analytics firms named the actor within hours from on-chain links [12] (**Reported**); the government record followed two days later [28] (**Confirmed**).

Sources

Sources [1] to [23] and [25] to [27] were opened on 11 November 2026; [24], [28] and [29] were opened on 12 November 2026.

#	Source	URL	Opened	Grade
1	Binance, preliminary investigation post-mortem (Binance Square), latest update 3 Nov 2026	binance.com/square/post/384314395829022	2026-11-11	Confirmed
2	Binance, initial incident report (blog), 3 Nov 2026	binance.com/en/blog/community/322915344375956763	2026-11-11	Confirmed
3	Binance, Security Incident Update #2, 30 Oct 2026	binance.com/square/post/382966351297065	2026-11-11	Confirmed
4	Binance, Recovery Update #4, 1 Nov 2026	binance.com/square/post/383446817991353	2026-11-11	Confirmed
5	CISA, FBI and Treasury, AA22-108A, TraderTraitor, 18 Apr 2022, revised 20 Apr 2022	cisa.gov/news-events/cybersecurity-advisories/aa22-108a	2026-11-11	Confirmed
6	FBI IC3, I-022625-PSA, Bybit theft, 26 Feb 2025	ic3.gov/PSA/2025/PSA250226	2026-11-11	Confirmed
7	FBI IC3, PSA index	ic3.gov/PSA	2026-11-11	Demonstrated
8	FBI IC3, I-101326-PSA, North Korean IT workers, 13 Oct 2026	ic3.gov/PSA/2026/PSA261013	2026-11-11	Confirmed
9	TRM Labs, North Korea steals $6.36 billion from Binance, 30 Oct 2026	trmlabs.com/resources/blog/...	2026-11-11	Confirmed (TRM's figures); Reported (attribution)
10	TRM Labs, Binance hack update: laundering, 3 Nov 2026	trmlabs.com/resources/blog/...	2026-11-11	Reported

#	Source	URL	Opened	Grade
11	TRM Labs, North Korea has stolen $12.8 billion in crypto, 30 Oct 2026, updated 3 Nov	trmlabs.com/resources/blog/...	2026-11-11	Confirmed (TRM's figures)
12	Chainalysis, Binance exploit: latest findings and response, 30 Oct 2026, updated 3 Nov	chainalysis.com/blog/binance-exploit-latest-findings-and-response/	2026-11-11	Confirmed (Chainalysis's figures); Reported (attribution)
13	Chainalysis, Binance hack and DPRK employment fraud, 3 Nov 2026	chainalysis.com/blog/binance-hack-dprk-employment-fraud/	2026-11-11	Reported
14	Elliptic, Binance: the largest hack in history, 30 Oct 2026, updated 1 Nov	elliptic.co/insights/binance-largest-hack-in-history/	2026-11-11	Confirmed (Elliptic's figures); Reported (attribution)
15	TechCrunch, Binance pauses withdrawals, 29 Oct 2026	techcrunch.com/2026/10/29/...	2026-11-11	Reported
16	BleepingComputer, Binance probes potential $5.8 billion theft, 29 Oct 2026	bleepingcomputer.com/news/security/...	2026-11-11	Reported
17	BleepingComputer, Binance links theft to compromised DevOps laptop, 30 Oct 2026	bleepingcomputer.com/news/security/...	2026-11-11	Reported
18	BleepingComputer, FBI links Binance heist to North Korean hackers, 1 Nov 2026	bleepingcomputer.com/news/security/...	2026-11-11	Reported
19	The Hacker News, FBI links North Korea's TraderTraitor to Binance theft, 1 Nov 2026	thehackernews.com/2026/11/...	2026-11-11	Reported
20	The Record, FBI blames TraderTraitor for Binance hack, 2 Nov 2026	therecord.media/fbi-blames-tradertraitor-for-binance-hack	2026-11-11	Reported
21	The Record, Binance theft was a months-long campaign, 3 Nov 2026	therecord.media/...	2026-11-11	Reported
22	Cointelegraph, North Korea linked to Binance hack by crypto investigators, 30 Oct 2026	cointelegraph.com/news/...	2026-11-11	Reported
23	TeamStarWolf Intelligence Hub, feed (index only)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Demonstrated
24	TeamStarWolf library, North Korea-Attributed Threat Actors: The Public Record	/case-studies/THREAT_ACTORS_NORTH_KOREA.md	2026-11-12	Confirmed
25	TeamStarWolf library, npm Supply Chain Attacks	/case-studies/NPM_SUPPLY_CHAIN_ATTACKS.md	2026-11-11	Confirmed
26	TeamStarWolf library, PHP2Shell and October 2026	/case-studies/PHP2SHELL_OCTOBER_2026.md	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
27	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `data/attack/groups.jsonl`, `data/attack/campaigns.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/attack/d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl` and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-11	Confirmed
28	FBI, cyber alert, North Korea Responsible for $6 Billion+ Binance Attack, 31 Oct 2026	fbi.gov/investigate/cyber/alerts/2026/...	2026-11-12	Confirmed
29	TeamStarWolf library, The Year 2026 in Intrusions: A Dated Record	/case-studies/CHRONICLE_2026.md	2026-11-12	Confirmed

Not opened, so not cited as sources: the KCNA statement, the US Secret Service post on X, the Tether and Circle CEO posts on X, Binance's and its executives' posts on X, and the SANS Internet Storm Center diary on a trojanized Homebrew installer (bot wall); each is relayed by a source above or left out. The CISA KEV catalog was not checked for this brief.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- North Korea-Attributed Threat Actors, The Year 2026 in Intrusions, npm Supply Chain Attacks, PHP2Shell and October 2026, AI Threats in the Cybersecurity Industry
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Blockchain Security Reference, Social Engineering Reference, Secrets Management Reference, Container Security Reference, Endpoint Security Reference, AI Security Reference
- Vulnerability Prioritization Reference, Vulnerability Management Reference
- Groups and campaigns: G0082 APT38, G0032 Lazarus Group, G1052 Contagious Interview, C0022 Operation Dream Job
- Techniques: T1591.004 Identify Roles, T1608.001 Upload Malware, T1566.003 Spearphishing via Service, T1204.002 Malicious File, T1036.005 Match Legitimate Resource Name or Location, T1072 Software Deployment Tools, T1552 Unsecured Credentials, T1550.001 Application Access Token, T1610 Deploy Container, T1070 Indicator Removal, T1657 Financial Theft

- CAPEC: CAPEC-163, CAPEC-616, CAPEC-593
- Navigator layers, including this study's layer, binance-heist-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies